National Cyber Security Centre
a part of GCHQ

Advisory

APT28 exploit routers to enable DNS hijacking operations

Version 1

07 April 2026

© Crown Copyright 2026

APT28 exploit routers to enable DNS hijacking operations

Executive summary

Russian cyber actors APT28 have been exploiting routers to overwrite Dynamic Host Configuration Protocol (DHCP)/Domain Name System (DNS) settings to redirect traffic through attacker-controlled DNS servers. Resulting malicious DNS resolutions enable adversary-in-the-middle (AitM) attacks that harvest passwords, OAuth tokens and other credentials for web and email related services. This puts organisations at risk of credential theft, data manipulation and broader compromise.

The DNS hijacking operations are believed to be opportunistic in nature, with the actor targeting a wide pool of victims and then likely filtering down for users of potential intelligence value at each stage of the exploitation chain.

APT28 exploit routers to enable DNS hijacking operations

Introduction

The UK National Cyber Security Centre (NCSC) is providing details of tactics, techniques and procedures (TTPs) associated with APT28's exploitation of routers to enable DNS hijacking operations.

The DNS protocol resolves human-readable domain names, for example ncsc.gov.uk, to their associated IP addresses, for example 1.2.3[.]4, through a process called DNS resolution.

DNS hijacking (also known as DNS poisoning or DNS redirection) is a cyber attack where DNS records or responses are manipulated in order to redirect clients to malicious infrastructure that hosts services such as phishing websites or software that attempts to steal user credentials.

We assess that APT28 is almost certainly the Russian General Staff Main Intelligence Directorate (GRU) 85th Main Special Service Centre (GTsSS) Military Intelligence Unit 26165. APT28 (also known as Forest Blizzard, Fancy Bear, STRONTIUM, the Sednit Gang and Sofacy) is a highly skilled threat actor.

The NCSC has previously attributed the following activity to APT28:

- Cyber attacks against the German parliament in 2015, including data theft and disrupting email accounts of German Members of Parliament (MPs) and the Vice Chancellor
- An attempted attack against the Organisation for the Prohibition of Chemical Weapons (OPCW) in April 2018, to disrupt independent analysis of chemicals weaponised by the GRU in the UK

For more information on APT28 activity, see the advisories 'Russian State-Sponsored and Criminal Cyber Threats to Critical Infrastructure', 'APT28 exploits known vulnerability to carry out reconnaissance and deploy malware on cisco routers' and 'UK and allies expose Russian intelligence campaign targeting western logistics and technology organisations'.

APT28 malicious DNS activity

Since 2024 and into 2026, APT28 has been configuring Virtual Private Servers (VPSs) to operate as malicious DNS servers [T1583.002, T1583.003]. These VPSs typically receive high volumes of DNS requests originating from routers that had been exploited by the actor likely utilising public vulnerabilities [T1584.008, T1588.006]. Investigations into this activity identified the following two banner pattern clusters containing multiple VPSs each.

Cluster one

The DHCP DNS server settings of compromised small office/home office (SOHO) routers were modified to include actor-owned IP addresses. These settings were subsequently inherited by downstream devices, for example laptops and phones.

Lookups for domain names containing key terms associated with particular services, often email applications or login pages, would then be resolved by the malicious DNS servers to further actor-owned IP addresses. DNS requests not matching the actor's targeting criteria would instead be resolved to the legitimate IP addresses for the requested services.

The actor would then attempt to conduct adversary-in-the-middle (AitM) attacks against follow-on connections with the likely aim of harvesting user account credentials [T1557, T1586].

An AitM attack occurs when an attacker inserts itself into the middle of a communication between two parties, enabling the attacker to read and potentially change the content of that communication.

The AitM activity could be conducted against both user browser sessions and desktop applications. Harvested authentication material could include both passwords and OAuth or similar authentication tokens. Subsequent malicious logins using this stolen data **may originate from further infrastructure** not listed in this advisory.

It is believed that the DNS hijacking operations are opportunistic in nature, with the actor gaining visibility of a large pool of candidate target users then filtering

down users at each stage in the exploitation chain to triage for victims of likely intelligence value.

TP-Link router exploitation

One of the router models that APT28 exploited for their DNS poisoning operations was the TP-Link WR841N, likely using CVE-2023-50224 [T1584.008, T1588.006]. This vulnerability enables an unauthenticated attacker to obtain information such as password credentials via specially crafted HTTP GET requests.

Having obtained the credentials for a router, the actor was then able to send a second specially crafted HTTP GET request to alter the DHCP DNS settings of that router.

The GET request would typically set the router's primary DNS server to a malicious IP address, whilst also setting the secondary DNS server to the original primary DNS server's IP address. On occasion both the primary and secondary DNS server had been set to malicious IP addresses, indicating that a router had likely been exploited multiple times.

Other TP-Link router models were also targeted by APT28 to enable their DNS hijacking operations. A list can be found in the Indicators of Compromise section.

Cluster two

A subset of servers in this cluster received DNS requests via likely compromised devices including models of MikroTik and TP-Link routers. The DNS requests were forwarded from these servers to further remote actor-owned servers.

This cluster of infrastructure was also involved in interactive operations against a small number of MikroTik routers, often located in Ukraine, that were likely of intelligence value to the actor.

Indicators of compromise

Known malicious and targeted infrastructure is listed below. Specific selectors are **liable to change** and it is therefore recommended that holistic tradecraft is used to detect DNS hijacking and AitM activity.

VPS banners

	Banners
Banner pattern 1	SSH on TCP port 56777 "dnsmasq-2.85" on UDP port 53
Banner pattern 2	SSH on TCP port 35681 "dnsmasq-2.85" on UDP port 53

For banner pattern 2, the DNS software was only present on some servers.

TP-Link router models exploited by APT28

The following is a list of TP-Link router models targeted by APT28. It is likely that this list is not exhaustive.

Router model
TP-LINK LTE WIRELESS N ROUTER MR6400
TP-LINK WIRELESS DUAL BAND GIGABIT ROUTER ARCHER C5
TP-LINK WIRELESS DUAL BAND GIGABIT ROUTER ARCHER C7
TP-LINK WIRELESS DUAL BAND GIGABIT ROUTER WDR3600
TP-LINK WIRELESS DUAL BAND GIGABIT ROUTER WDR4300
TP-LINK WIRELESS DUAL BAND ROUTER WDR3500
TP-LINK WIRELESS LITE N ROUTER WR740N
TP-LINK WIRELESS LITE N ROUTER WR740N/WR741ND
TP-LINK WIRELESS LITE N ROUTER WR749N
TP-LINK WIRELESS N 3G/4G ROUTER MR3420
TP-LINK WIRELESS N ACCESS POINT WA801ND
TP-LINK WIRELESS N ACCESS POINT WA901ND
TP-LINK WIRELESS N GIGABIT ROUTER WR1043ND
TP-LINK WIRELESS N GIGABIT ROUTER WR1045ND
TP-LINK WIRELESS N ROUTER WR840N
TP-LINK WIRELESS N ROUTER WR841HP
TP-LINK WIRELESS N ROUTER WR841N
TP-LINK WIRELESS N ROUTER WR841N/WR841ND
TP-LINK WIRELESS N ROUTER WR842N
TP-LINK WIRELESS N ROUTER WR842ND
TP-LINK WIRELESS N ROUTER WR845N
TP-LINK WIRELESS N ROUTER WR941ND
TP-LINK WIRELESS N ROUTER WR945N

Targeted domains

The following domain names were targeted by APT28 for redirection to AitM infrastructure. Further non-Outlook related domains were also noted.

Domain name
autodiscover-s.outlook[.]com
imap-mail.outlook[.]com
outlook.live[.]com
outlook.office[.]com
outlook.office365[.]com

APT28 infrastructure

The following IP addresses were associated with the first cluster of malicious APT28 DNS servers and AitM infrastructure.

IP Address
5.226.137[.]151
5.226.137[.]230
5.226.137[.]231
5.226.137[.]232
5.226.137[.]234
5.226.137[.]235
5.226.137[.]242
5.226.137[.]243
5.226.137[.]244
5.226.137[.]245
23.106.120[.]119
37.221.64[.]77
37.221.64[.]78
37.221.64[.]93
37.221.64[.]101
37.221.64[.]116
37.221.64[.]131
37.221.64[.]148
37.221.64[.]149
37.221.64[.]150
37.221.64[.]151
37.221.64[.]163
37.221.64[.]173
37.221.64[.]199
37.221.64[.]208
37.221.64[.]224
37.221.64[.]254
64.120.31[.]96
64.120.31[.]97
64.120.31[.]98
64.120.31[.]99
64.120.31[.]100

77.83.197[.]37
77.83.197[.]38
77.83.197[.]39
77.83.197[.]40
77.83.197[.]41
77.83.197[.]42
77.83.197[.]43
77.83.197[.]44
77.83.197[.]45
77.83.197[.]46
77.83.197[.]47
77.83.197[.]48
77.83.197[.]49
77.83.197[.]50
77.83.197[.]51
77.83.197[.]52
77.83.197[.]53
77.83.197[.]54
77.83.197[.]55
77.83.197[.]56
77.83.197[.]57
77.83.197[.]58
77.83.197[.]59
77.83.197[.]60
79.141.160[.]78
79.141.161[.]66
79.141.161[.]67
79.141.161[.]68
79.141.161[.]69
79.141.161[.]70
79.141.161[.]71
79.141.161[.]72
79.141.161[.]73
79.141.161[.]74
79.141.161[.]75
79.141.161[.]76
79.141.161[.]77
79.141.161[.]78
79.141.161[.]79
79.141.161[.]80
79.141.161[.]81
79.141.161[.]82
79.141.161[.]83
79.141.161[.]84
79.141.161[.]85
79.141.173[.]70
79.141.173[.]96
79.141.173[.]97
79.141.173[.]98
79.141.173[.]103
79.141.173[.]119
79.141.173[.]120
79.141.173[.]121
79.141.173[.]122
79.141.173[.]211
79.141.173[.]231

79.141.173[.]232
79.141.173[.]233
185.117.88[.]22
185.117.88[.]28
185.117.88[.]29
185.117.88[.]30
185.117.88[.]31
185.117.88[.]50
185.117.88[.]60
185.117.88[.]61
185.117.88[.]62
185.117.89[.]32
185.117.89[.]46
185.117.89[.]47
185.237.166[.]55
185.237.166[.]56
185.237.166[.]57
185.237.166[.]58
185.237.166[.]59
185.237.166[.]60
185.237.166[.]61
185.237.166[.]62
185.237.166[.]63
185.237.166[.]64
185.237.166[.]65
185.237.166[.]66
185.237.166[.]67
185.237.166[.]68
185.237.166[.]69
185.237.166[.]70
185.237.166[.]71
185.237.166[.]72
185.237.166[.]73
185.237.166[.]74
185.237.166[.]75
185.237.166[.]224
185.237.166[.]225
185.237.166[.]226
185.237.166[.]227
185.237.166[.]228
185.237.166[.]229
185.237.166[.]230
185.237.166[.]231
185.237.166[.]232
185.237.166[.]233
185.237.166[.]234
185.237.166[.]235
185.237.166[.]236
185.237.166[.]237
185.237.166[.]238
185.237.166[.]239
185.237.166[.]240
185.237.166[.]241
185.237.166[.]242
185.237.166[.]243
185.237.166[.]244

185.237.166[.]245
185.237.166[.]246
185.237.166[.]247
185.237.166[.]248
185.237.166[.]249

The following IP addresses were associated with the second cluster of APT28 infrastructure involved in DNS hijacking and wider router operations.

IP Address
64.44.154[.]227
64.44.154[.]237
64.44.154[.]238
64.44.154[.]239
64.44.154[.]240
77.83.198[.]39
79.141.173[.]123
79.141.173[.]200
79.141.173[.]210
79.141.173[.]246
79.141.173[.]247
79.141.173[.]248
79.141.173[.]249
79.141.173[.]250
79.141.173[.]251
79.141.173[.]252
79.141.173[.]253
79.141.173[.]254
79.143.87[.]229
79.143.87[.]232
79.143.87[.]240
79.143.87[.]243
79.143.87[.]249
88.80.148[.]49
88.80.148[.]53
89.150.40[.]43
89.150.40[.]86
103.140.186[.]148
103.140.186[.]149
103.140.186[.]155
185.234.73[.]58
185.234.73[.]61
185.234.73[.]62

MITRE ATT&CK®

This report has been compiled with respect to the MITRE ATT&CK® framework, a globally accessible knowledge base of adversary tactics and techniques based on real-world observations.

Tactic	ID	Technique	Procedure
Initial Access	T1190	Exploit Public-Facing Application	APT28 exploited vulnerabilities in internet facing routers.
Credential Access	T1557	Adversary-in-the-Middle	APT28 conducted AitM attacks to gather account credentials.
Resource Development	T1583.002	Acquire Infrastructure: DNS Server	APT28 operated malicious DNS servers to conduct DNS hijacking activities.
Resource Development	T1583.003	Acquire Infrastructure: Virtual Private Server	APT28 used VPS infrastructure to host malicious DNS servers for conducting DNS hijacking activities.
Resource Development	T1584.008	Compromise Infrastructure: Network Devices	APT28 compromised routers to enable their DNS hijacking activity.
Resource Development	T1586	Compromise Accounts	APT28 used DNS hijacking and AitM techniques to gather account credentials.
Resource Development	T1588.006	Obtain Capabilities: Vulnerabilities	APT28 used public vulnerabilities to exploit routers for use in their operations.

Mitigation

A number of mitigations will be useful in defending against the activity described in this advisory:

- **Protect the management interfaces of your systems.** In particular, use browse-down architecture to prevent attackers easily gaining privileged access to your most vital assets. Management interfaces must never be exposed to the internet. See NCSC blog post: https://www.ncsc.gov.uk/blog-post/protect-your-management-interfaces

- **Protect your devices and networks by keeping them up to date**: use the latest supported versions, apply security updates promptly, use antivirus and scan regularly to guard against known malware threats. See NCSC guidance: https://www.ncsc.gov.uk/collection/device-security-guidance/policies-and-settings/antivirus-and-other-security-software

- **Use modern systems and software**. These have better security built in. If you cannot move off out-of-date platforms and applications straight away, there are short term steps you can take to improve your position. See NCSC guidance: https://www.ncsc.gov.uk/collection/device-security-guidance/managing-deployed-devices/obsolete-products

- **Update your systems and software. Ensure your operating system and productivity apps are up to date.** Users with Office 365 licensing can use 'click to run' to keep their office applications seamlessly updated. See NCSC guidance: https://www.ncsc.gov.uk/collection/device-security-guidance/managing-deployed-devices/keeping-devices-and-software-up-to-date

- **Set up a security monitoring capability** so you are collecting the data that will be needed to analyse network intrusions. See NCSC guidance: https://www.ncsc.gov.uk/guidance/introduction-logging-security-purposes and CISA's Logging Made Easy: https://www.cisa.gov/resources-tools/services/logging-made-easy

- **Add applications to an allowlist.** If supported by your operating environment, consider adding permitted applications to an allowlist. This will help prevent malicious applications from running. See NCSC guidance: https://www.ncsc.gov.uk/collection/device-security-guidance/platform-guides

- **Deploy a host-based intrusion detection system**. A variety of products are available, free and paid-for, to suit different needs and budgets.

- **Use multi-factor authentication** (/2-factor authentication/two-step authentication) to reduce the impact of password compromises. See NCSC guidance: https://www.ncsc.gov.uk/collection/mfa-for-your-corporate-online-services and https://www.ncsc.gov.uk/guidance/setting-2-step-verification-2sv

- **Treat people as your first line of defence**. Tell staff how to report suspicious activity, and ensure they feel confident to do so. Investigate their reports promptly and thoroughly. Never punish users for clicking phishing links or opening attachments.

- **Further information**: Invest in preventing malware-based attacks across various scenarios. See NCSC guidance: https://www.ncsc.gov.uk/guidance/mitigating-malware-and-ransomware-attacks

Disclaimer

This report draws on information derived from NCSC and industry sources. Any NCSC findings and recommendations made have not been provided with the intention of avoiding all risks and following the recommendations will not remove all such risk. Ownership of information risks remains with the relevant system owner at all times.

This information is exempt under the Freedom of Information Act 2000 (FOIA) and may be exempt under other UK information legislation.

Refer any FOIA queries to ncscinfoleg@ncsc.gov.uk.

All material is UK Crown Copyright ©